UNIVERSITE LIBRE
DE BRUXELLES

HIBERT PROBLEMS IN CYBERSECURITY

2025-2026

Ch. Cuvelliez

PROBLEM 1

HOW TO RELIABLY DESIGN SYSTEMS SECURE FROM THE START (SECURITY BY DESIGN) AND EVOLVE THEM SECURELY IN RESPONSE TO CHANGING NEEDS (SECURITY BY DEFAULT)?

Few practices demonstrate that software and firmware components meet all security criteria. Advances range from tools and best practices to modeling techniques, improved programming languages, proof management, and strengthening developer/evaluator skills—yet these remain limited.

Key Challenges

- **Development pressure**: Tight deadlines combined with the belief that security is costly, slow, and hard to measure discourage developers.
- **Lack of incentives**: Without reliable methods to assess quality and security, no sufficient motivation emerges, and no one invests in creating them.

Core Problem

- The fundamental challenge is designing systems that are secure by design (secure from inception) and secure by default (capable of evolving securely).

PROBLEM 2: SECURE COMPOSITION (1/2)

WHAT TECHNICAL PRINCIPLES ENABLE SECURE INTEGRATION OF LARGE-SCALE SYSTEMS FROM DIVERSE COMPONENTS/SERVICES

Complex Systems Construction

- Built by combining components/services with varying security levels, due to teams with different expertise levels

Secure Composition Goal

- Trust entire system security based only on parts' evaluations

Success Factors are

- Technical properties of each component
- Design choices during integration
- Management of cross-dependencies

Component Types

- Underlying OS
- Open source software libraries
- Dependencies on other OT physical systems

Version Challenges

- Not always latest versions (retro-compatibility, unavailability)
- Impossible to update all dependencies simultaneously

Human Factor

- Skills of designers/developers
- Deep knowledge of assembled system

PROBLEM 2: SECURE COMPOSITION (2/2)

WHAT TECHNICAL PRINCIPLES ENABLE SECURE INTEGRATION OF LARGE-SCALE SYSTEMS FROM DIVERSE COMPONENTS/SERVICES

Development Platforms

- GitHub-like: reusable components/services
- Help assemble systems, organize resources
- Enable automated integration testing

Ideal Architecture

- Reduce interdependencies between components
- Promote resilience
- One component failure → no propagation

Resilience Testing Limits

- Fault injection tests = non-exhaustive
- Occur at late stage → too late if issues found

Secure Composition Timing

- Happens at design phase (early)
- Adding resilience late = very complex

PROBLEM 3: SUPPLY CHAIN (1/2)

HOW CAN WE SECURELY DEVELOP AND MANAGE COMPLEX SOFTWARE/HARDWARE SYSTEMS WHEN THEIR COMPONENTS AND SERVICES COME FROM DIVERSE SOURCES?

Secure Subcontractor Management:

After achieving (or to achieve) secure composition of complex systems, securely managing subcontractors becomes critical, as these systems integrate components from numerous diverse suppliers.

Diverse Supply Sources:

Components come from commercial companies, open source projects, independent developers, or cloud services—each subject to varying regulations by country/sector and different competency levels.

Supplier Reluctance:

Suppliers, keen to protect trade secrets, often hesitate to disclose detailed component information, even to customers or other supply chain actors.

Updates Challenges:

Updates are essential to patch vulnerabilities but require thorough compatibility testing;

Missing updates necessitate isolating or encapsulating insecure components to prevent system-wide compromise.

PROBLEM 3: SUPPLY CHAIN (2/2)

HOW CAN WE SECURELY DEVELOP AND MANAGE COMPLEX SOFTWARE/HARDWARE SYSTEMS WHEN THEIR COMPONENTS AND SERVICES COME FROM DIVERSE SOURCES?

SBOM Limitations:

Software Bill of Materials (SBOM) provides partial solutions but remains limited, addressing only some potential risks.

Open Source Reality:

Only a small fraction of open source projects receives sustained attention to code quality and security, despite promises of direct evaluation and community-shared maintenance..

Missing Supply Chain Model:

No reliable supply chain model exists today that guarantees—through robust practices and evidence—that all components/services meet required security standards

PROBLEM 4: ECONOMIC INCENTIVES (1/2)

HOW TO ESTABLISH ACCOUNTABILITY AND RESPONSIBILITY MECHANISMS THAT ENCOURAGE HIGHER SECURITY LEVELS AND RAPID INNOVATION

Lack of Provider Accountability:
Cybersecurity product suppliers are rarely held accountable, even for poor-quality products, with few incentives rewarding high-quality offerings.

Limited Market Incentives:
Brand reputation and informed customer demand can encourage better practices in some cases, but these remain exceptions rather than the norm.

Resistance to Regulation:
Suppliers oppose stricter regulations, arguing that increased liability would stifle innovation and harm national competitiveness.

CrowdStrike Example:
Recall the CrowdStrike update that paralyzed many organizations—no accountability engaged to date, highlighting systemic issues.

Self-Certification Flaws:
Suppliers favor self-certification over liability, but compliance with standards doesn't guarantee real security and can be manipulated.

PROBLEM 4: ECONOMIC INCENTIVES (2/2)

HOW TO ESTABLISH ACCOUNTABILITY AND RESPONSIBILITY MECHANISMS THAT ENCOURAGE HIGHER SECURITY LEVELS AND RAPID INNOVATION

Measurement Challenges:

Objective security measurement difficulties complicate progress evaluation and accountability enforcement.

Legal Liability Barriers:

Proposals for legal responsibility on certain failures face obstacles:

1. Fixed standards can't keep pace with rapid evolution
2. High litigation costs, inaccessible to most affected users

PROBLEM 5: MAN-MACHINE INTERFACE (1/2)

HOW TO DESIGN SYSTEMS THAT REDUCE CYBERCRIMINALS' ABILITY TO EXPLOIT HUMAN BEHAVIOR TO ACCESS SYSTEMS?

Poorly Designed Human Interfaces:

- Many computer system interfaces are confusing and poorly designed, even for experts, affecting authentication, privacy management, access configuration, and alert responses—making human error the primary security vulnerability.

Flawed Design Philosophy:

- Designers **overly rely on user training and awareness programs**, while attackers systematically exploit human vulnerabilities.

Effective Solution:

- The most successful approaches use better-designed interfaces tailored to actual user capabilities, **rather than expecting users to compensate for poor design**

PROBLEM 5: MAN-MACHINE INTERFACE (1/2)

HOW TO DESIGN SYSTEMS THAT REDUCE CYBERCRIMINALS' ABILITY TO EXPLOIT HUMAN BEHAVIOR TO ACCESS SYSTEMS?

Needed Discipline:

Requires a cybersecurity ergonomics science—user-centered secure design integrating security into the overall experience:

- Application protection
- Data privacy and governance

Core Requirements:

Must acknowledge human limitations, enabling users/operators to easily monitor, understand, and control collected/shared data (they understand and are aware with what happens to their data).

Key Challenges:

Achieve this without:

- Overwhelming users with complexity
- Reducing system efficiency
- Creating new attack vectors through excessive transparency

PROBLEM 6: MAN-MACHINE INTERFACE (2/2)

HOW TO DESIGN SYSTEMS THAT REDUCE CYBERCRIMINALS' ABILITY TO EXPLOIT HUMAN BEHAVIOR TO ACCESS SYSTEMS?

Poorly Designed Human Interfaces:

- Many computer system interfaces are confusing and poorly designed, even for experts, affecting authentication, privacy management, access configuration, and alert responses—making human error the primary security vulnerability.

Flawed Design Philosophy:

- Designers **overly rely on user training and awareness programs**, while attackers systematically exploit human vulnerabilities.

Effective Solution:

- The most successful approaches use better-designed interfaces tailored to actual user capabilities, **rather than expecting users to compensate for poor design**

PROBLEM 7: INFORMATION RELIABILITY (1/2)

HOW CAN SOCIAL NETWORKS SUPPORT FREEDOM OF EXPRESSION AND IDEA EXCHANGE WHILE PROTECTING USER SAFETY/PRIVACY AND RAISING AWARENESS OF MISINFORMATION

Targeted Manipulation at Scale:

- Digital platforms enable precise, large-scale targeting, facilitating opinion manipulation and scams through massive data collection to train manipulative algorithms.

Detection Technology Lag:

- Detection technologies struggle to keep pace with manipulations and deepfakes, exacerbated by the constantly evolving online media landscape.

Commercial Incentives Problem:

- Platforms prioritize user engagement for profit, causing algorithms to amplify harmful or misleading content.

PROBLEM 7: INFORMATION RELIABILITY (2/2)

HOW CAN SOCIAL NETWORKS SUPPORT FREEDOM OF EXPRESSION AND IDEA EXCHANGE WHILE PROTECTING USER SAFETY/PRIVACY AND RAISING AWARENESS OF MISINFORMATION

Accountability Gap:

Greater responsibility needed for how platforms collect/use personal data for algorithms/advertising:

- **DSA in Europe exists**, but heavily opposed by USA
- Still far from comprehensive global enforcement

Deepfake Proliferation:

Detection methods and digital watermarking techniques urgently need improvement:

- No longer limited to social media—now flooding e-commerce, dating apps, traditional media
- **Future threat:** AI video generators like Sora will make physical-world footage obsolete

PROBLEM 8: UBIQUITY OF CYBER PHYSICAL SYSTEMS (1/2)

HOW TO BETTER SECURE THE INTERNET OF THINGS AND ALL OPERATIONAL TECHNOLOGY DEVICES THAT RUN REAL-WORLD SYSTEMS

Cyber-Physical Systems (CPS) Scope:

- CPS operate in civil infrastructure, transportation, and IoT-connected devices including network hubs, security cameras, thermostats, TVs, home/industrial control systems, and various sensors.

Inherent Vulnerabilities:

- **Originally designed as isolated from networks**, leading to technical approaches with lower security standards than traditional IT systems.

Expertise Gap:

- Secure CPS design requires simultaneous hardware and software expertise, but most implementations **lack professionals competent in both domains**.

PROBLEM 8: UBIQUITY OF CYBER PHYSICAL SYSTEMS (2/2)

HOW TO BETTER SECURE THE INTERNET OF THINGS AND ALL OPERATIONAL TECHNOLOGY DEVICES THAT RUN REAL-WORLD SYSTEMS

Update Limitations:

- **Many CPS don't support remote updates for patches**, making it extremely difficult to securely redesign existing hardware/software architectures.

Real-Time Constraints:

- **Numerous CPS handle real-time control**, creating complex internal dependencies that complicate security hardening and resilience at both individual device and distributed network levels.

PROBLEM 9: AI (1/2)

HOW TO INTEGRATE ARTIFICIAL INTELLIGENCE INTO THE SECURE SOFTWARE DEVELOPMENT LIFECYCLE

AI Effectiveness Factors:

AI performance depends heavily on training data quality, which is often collected opportunistically, poorly maintained, biased, or inaccurate.

Data Challenges:

Training data issues extend beyond quality/security to complex legal concerns like copyright and data ownership.

Limited User Understanding:

Even advanced users can only form limited opinions about AI systems, overlooking their wide range of weaknesses and vulnerabilities.

Cognitive Biases:

Human biases like automation bias lead people to over-trust autonomous system decisions.

PROBLEM 9: AI (2/2)

HOW TO INTEGRATE ARTIFICIAL INTELLIGENCE INTO THE SECURE SOFTWARE DEVELOPMENT LIFECYCLE

Vast Attack Surface:

AI vulnerabilities span:

- Training data flaws
- Network architecture weaknesses
- Operational input risks
- Traditional software cybersecurity threats

Developer Responsibility:

AI developers must prioritize explicit human accountability and ensure secure outcomes in their designs.

PROBLEM 10: OPERATIONAL RESILIENCE (1/2)

HOW CAN OPERATIONAL RESILIENCE—PARTICULARLY RESPOND AND RECOVER PHASES—IN LARGE PRIVATE/GOVERNMENT ORGANIZATIONS BE IMPROVED AMID ACTIVE THREATS AND HIGH-STAKES CONSEQUENCES?

Growing Global Dependency:

Worldwide reliance on large-scale systems increases, including cloud infrastructures from AWS, Azure, Google, plus major applications like Microsoft/Google search engines and email services.

Limited User Visibility:

Users have restricted insight into these systems' security configurations, depending entirely on provider guarantees.

Resilience Requirements:

To withstand attacks/outages, systems must:

- Isolate compromised components for continued operation
- Enable eventual recovery
- This requires rapid detection, immediate impact assessment, and appropriate defensive measures

PROBLEM 10: OPERATIONAL RESILIENCE (2/2)

HOW CAN OPERATIONAL RESILIENCE—PARTICULARLY RESPOND AND RECOVER PHASES—IN LARGE PRIVATE/GOVERNMENT ORGANIZATIONS BE IMPROVED AMID ACTIVE THREATS AND HIGH-STAKES CONSEQUENCES?

Detection/Response Difficulties:

Attack identification and impact analysis are costly and error-prone.

Recovery Shortcomings:

Essential for security, **yet many organizations fail—evident in widespread ransomware incidents.**

Critical Infrastructure Risk:

Societal essential systems often depend on few key infrastructures (like cloud services), creating single points of catastrophic failure threatening security, availability, and integrity.

PROBLEM 11: CYBER-RISK MANAGEMENT (1/2)

HOW TO COMPREHENSIVELY ASSESS CYBER RISKS—FROM TECHNICAL VULNERABILITIES AND ATTACK SURFACES TO OPERATIONAL IMPACTS, RESILIENCE, AND EVOLVING THREATS?

Evaluating computer system security poses major challenges. Unlike physical systems with measurable properties, cybersecurity lacks reliable, reproducible metrics, often prioritizing easier-to-track aspects like performance over critical security.

Key Challenges

1. **Measurement gaps:**

   Physical systems allow lab-tested metrics (strength, conductivity); cybersecurity has few objective, scalable criteria—performance and uptime dominate despite security's primacy.

2. **Context and adversary dependency:**

   Risks vary by use case and attacker capabilities/motivation; underestimating them proves catastrophic. Unlike actuarial models for fires/floods, cyber threats involve hidden correlations (supply chains) and adaptive, secret attacker tactics.

PROBLEM 11: CYBER-RISK MANAGEMENT (2/2)

HOW TO COMPREHENSIVELY ASSESS CYBER RISKS—FROM TECHNICAL VULNERABILITIES AND ATTACK SURFACES TO OPERATIONAL IMPACTS, RESILIENCE, AND EVOLVING THREATS?

Evaluating computer system security poses major challenges. Unlike physical systems with measurable properties, cybersecurity lacks reliable, reproducible metrics, often prioritizing easier-to-track aspects like performance over critical security.

Key Challenges

1. **Measurement gaps:**

   Physical systems allow lab-tested metrics (strength, conductivity); cybersecurity has few objective, scalable criteria—performance and uptime dominate despite security's primacy.

2. **Context and adversary dependency:**

   Risks vary by use case and attacker capabilities/motivation; underestimating them proves catastrophic. Unlike actuarial models for fires/floods, cyber threats involve hidden correlations (supply chains) and adaptive, secret attacker tactics.